ISS 2103 • EXAM REVISION PACK 08

Network Security, Cryptography & Emerging Tech

Course outline weeks 8–9 (presentation layer: cryptography, network security) and week 12 (modern trends) Priority: **MEDIUM**

Security appears in every recent paper, but as **short** parts (1–6 marks): define a term, list threats, compare DES/AES, explain a VPN. As an Information Security student you should collect these marks quickly and use the extra detail here to write sharper answers.

How often this topic is examined

Question asked	Paper(s)	Marks
Discuss four network security threats	SE2024 Q2d	3
Competencies of a hacker	SE2024 Q4e(iii)	1
Harm caused by Trojans, worms, ransomware, spam	SE2024 Q5a(i)–(iv)	4×1
Differences between DES and AES	2023 Q4c	4
Define Key Distribution Centre (KDC)	2023 Q4d(i)	3
Define Certification Authority (CA)	2023 Q4d(ii)	3
How a VPN works	ISA2024 Q2a	3
Firewalls, IDS/IPS, digital signatures, Wi-Fi security, 5G/IoT/cloud	outline only	–

EXAM TIP

Start every security answer by naming the goal it protects (**C**onfidentiality, **I**ntegrity, **A**vailability). For definitions worth 3 marks give: what it is + how it works + an example.

1 Security goals, threats and attacks

1.1 Goals (the CIA triad plus two)

Goal	Meaning	Achieved by
Confidentiality	Only authorised parties can read the data	Encryption, access control
Integrity	Data is not altered in transit or storage	Hashes, MACs, digital signatures
Availability	Services and data are there when needed	Redundancy, backups, DoS protection
Authentication	Proving who a user or device is	Passwords, MFA, certificates
Non-repudiation	Sender cannot deny having sent a message	Digital signatures

1.2 Threats vs attacks

- A **threat** is a possible danger that could exploit a **vulnerability** (weakness); an **attack** is a deliberate attempt that carries a threat out. **Risk** = likelihood $\times$ impact.
- **Passive attack**: the attacker only *observes* (eavesdropping/sniffing, traffic analysis). Hard to detect; prevent with encryption. Attacks confidentiality.
- **Active attack**: the attacker *changes* or *disrupts* data (modification, replay, masquerade/spoofing, DoS). Easier to detect; attacks integrity and availability.

Attack	How it works
Sniffing / eavesdropping	Capturing packets on the network (e.g. Wireshark in promiscuous mode) to read unencrypted passwords and data. Passive.
Spoofing	Faking a source IP, MAC, e-mail or DNS reply to impersonate a trusted host (ARP spoofing, DNS poisoning).
DoS / DDoS	Flooding a server or link (SYN flood, ping flood) so legitimate users are refused. DDoS uses thousands of infected **botnet** machines at once.
Man-in-the-middle	Attacker secretly sits between two parties, relaying and possibly altering their traffic.
Phishing / social engineering	Tricking people (fake e-mail, website, call) into giving passwords or installing malware.
Password attacks	Brute force, dictionary attacks, credential stuffing with stolen passwords.
Replay	Recording a valid message (e.g. a login) and resending it later. Stopped by nonces and timestamps.

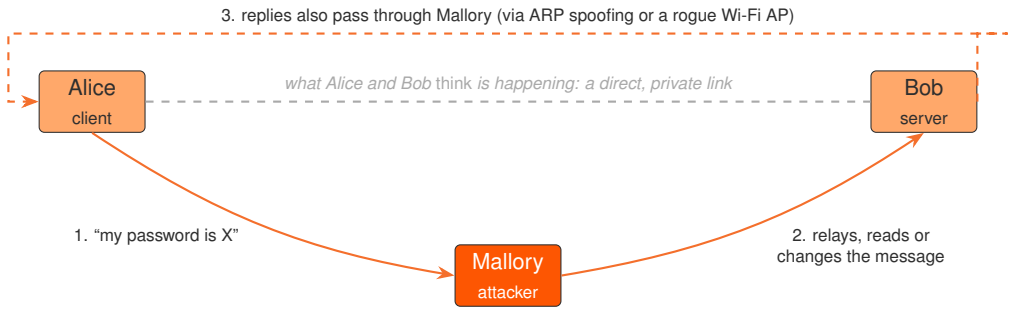


Figure: man-in-the-middle attack. Defence: encryption with authenticated keys (TLS + certificates, VPN), so Mallory sees only ciphertext and cannot fake the server.

PAST PAPER **SE2024 Q2d** **[3 marks]**

Discuss any four network security threats you are familiar with.

Model answer

1. **Malware**: viruses, worms, Trojans and ransomware that damage systems, steal data or lock files.
2. **Denial of Service (DoS/DDoS)**: flooding a server or link with traffic (often from a botnet) so legitimate users cannot reach it; attacks availability.
3. **Man-in-the-middle / eavesdropping**: an attacker intercepts traffic (ARP spoofing, rogue Wi-Fi) to read or alter it; attacks confidentiality and integrity.
4. **Phishing / social engineering**: fake e-mails or sites trick users into revealing passwords or card details.

Others accepted: spoofing, password attacks, SQL injection, insider threats, zero-day exploits.

PAST PAPER **SE2024 Q4e(iii)** **[1 marks]**

Write brief notes about the competencies expected of the following professionals: A hacker.

Only 3 marks for four threats: one crisp line each. Name the threat **and** the harm it does.

Model answer

A (ethical) hacker needs deep knowledge of networking and protocols (TCP/IP, OSI), operating systems (Linux, Windows), programming/scripting (Python, Bash), and security tools for scanning and penetration testing (Nmap, Metasploit, Wireshark) to find and exploit vulnerabilities, plus knowledge of law and ethics (white hat works with permission, e.g. CEH certified; black hat attacks illegally).

2 Malware

Type	Behaviour	Spreads by
Virus	Attaches to a host file/program; runs when the file is opened	User action (opening file)
Worm	Stand-alone, **self-replicating** across the network via vulnerabilities	By itself, no user needed
Trojan horse	Disguised as useful software; opens a back-door; does **not** self-copy	User installs it
Ransomware	Encrypts files and demands payment for the key	Phishing, worms (WannaCry)
Spyware / keylogger	Secretly records activity, keystrokes, pass-words	Bundled downloads
Rootkit	Hides deep in the OS to keep admin-level access	Trojans, exploits
Botnet (bot)	Infected machines remotely controlled for DDoS or spam	Any of the above
Spam	Unsolicited bulk e-mail (not malware itself, but a carrier)	E-mail

PAST PAPER **SE2024 Q5a(i)–(iv)** **[4 × 1 marks]**

Explain the harm caused by the following: (i) Trojans (ii) Worms (iii) Ransomware (iv) Spam.

Model answer

(i) **Trojans**: pose as legitimate software, then open a backdoor so the attacker can remotely control the PC, steal passwords and banking details, or install more malware.
(ii) **Worms**: copy themselves across the network without user action, consuming bandwidth and CPU (slowing or crashing networks) and carrying payloads such as ransomware.
(iii) **Ransomware**: encrypts the victim's files or locks the system and demands a ransom for the key, causing data loss, downtime and financial loss.
(iv) **Spam**: unsolicited bulk e-mail that wastes bandwidth, storage and staff time, and carries phishing links and malware attachments.

REMEMBER IT

Virus needs a host and a user. **Worm** walks by itself. **Trojan** tricks you in. **Ransomware** holds your files hostage.

3 Firewalls, DMZ and IDS/IPS

A **firewall** is hardware or software that filters traffic between a trusted and an untrusted network according to a **rule set** (allow/deny by IP, port, protocol, state).

Firewall type	How it filters
Packet filter (stateless)	Checks each packet's header (source/destination IP, port, protocol) against an ACL. Fast but no context. Layers 3–4.
Stateful inspection	Tracks connections in a state table; only replies belonging to an established session are allowed back in.
Application gateway (proxy)	Works at layer 7; understands HTTP, FTP etc. and can filter content. Slower.
Next-generation (NGFW)	Stateful + deep packet inspection + built-in IPS + application awareness.

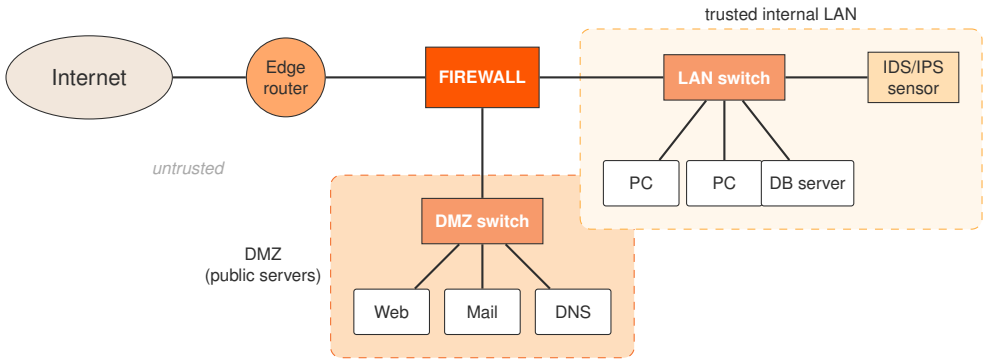


Figure: three-legged firewall. Outsiders may reach only the DMZ servers; the internal LAN accepts only replies to its own connections.

- **DMZ** (demilitarised zone): a separate network for servers the public must reach (web, mail, DNS). If one is hacked, the attacker is still outside the internal LAN.
- **IDS** (Intrusion Detection System): monitors a copy of the traffic and **alerts** the administrator. **IPS** (Intrusion Prevention System): sits **inline** and **blocks** the malicious traffic automatically.
- Detection methods: **signature-based** (matches known attack patterns; misses new attacks) and **anomaly-based** (learns normal behaviour, flags deviations; catches zero-days but more false positives). NIDS watches the network, HIDS one host.

IDS = burglar **alarm** (detect and alert). IPS = security **guard** (detect and stop). A firewall decides by rules; an IDS/IPS looks inside the traffic for attacks.

4 Cryptography: symmetric and asymmetric

Encryption transforms plaintext into ciphertext using an algorithm (cipher) and a key; **decryption** reverses it. In the OSI model it is a job of the **presentation layer**.

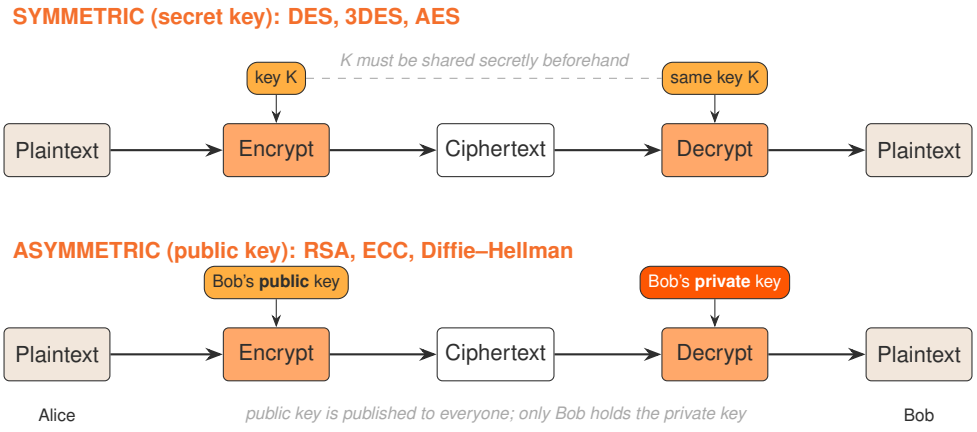


Figure: symmetric encryption uses one shared key; asymmetric uses a key pair.

Point	Symmetric	Asymmetric
Keys	One shared secret key	Key pair: public + private
Speed	Very fast; used for bulk data	100–1000× slower; used for small data (keys, signatures)
Key distribution	The big problem: needs a secure channel or a KDC	Easy: public key can be sent openly (trust via CA)
Keys for n users	$n(n-1)/2$	$2n$ (one pair each)
Services	Confidentiality	Confidentiality, authentication, non-repudiation
Examples	DES, 3DES, AES, RC4	RSA, ECC, Diffie–Hellman, DSA

Real systems (TLS, VPNs) are **hybrid**: asymmetric crypto swaps a random session key, then fast symmetric AES encrypts the data.

4.1 DES vs AES

PAST PAPER **2023 Q4c** **[4 marks]**

Highlight the major differences between DES and AES encryption methods.

Model answer

Feature	DES	AES
Origin	IBM, adopted by NIST 1977	Rijndael, adopted by NIST 2001 to replace DES
Key length	**56 bits** (64 with parity)	**128, 192 or 256 bits**
Block size	64 bits	128 bits
Structure	Feistel network	Substitution–permutation network (SubBytes, ShiftRows, MixColumns, AddRoundKey)
Rounds	16	10 / 12 / 14 (by key size)
Security	Broken by brute force (1998–99, under a day); 3DES was a stop-gap	No practical attack; used in WPA2/3, HTTPS, VPNs
Speed	Slow in software	Fast in hardware and software

Why 56 bits is too short: brute force at 10^{12} keys per second

$$\text{DES: } 2^{56} \approx 7.2 \times 10^{16} \text{ keys} \quad \leftarrow \textit{try every key}$$
$$7.2 \times 10^{16} / 10^{12} = 7.2 \times 10^{4} \text{ s} \approx 20 \textbf{ hours} \quad \leftarrow \div 3600$$
$$\text{AES-128: } 2^{128} \approx 3.4 \times 10^{38} \text{ keys}$$
$$3.4 \times 10^{38} / 10^{12} = 3.4 \times 10^{26} \text{ s} \approx 1.1 \times 10^{19} \textbf{ years} \quad \leftarrow \div 3.15 \times 10^{7} \textit{ s/year}$$

TRAP – where students lose marks

Each extra key bit **doubles** the work, so AES-128 is not "72 bits better" but 2^{72} **times** harder than DES. Also: DES key is 56 bits, not 64 (8 are parity).

4.2 Hashing and digital signatures

- A **hash function** (SHA-256; MD5 and SHA-1 are now weak) turns any message into a short fixed-length **digest**. One-way; any change to the message changes the digest. Gives **integrity**.
- A **digital signature** = the hash of the message encrypted with the **sender's private key**. Anyone verifies it with the sender's **public key**. Gives integrity, authentication and **non-repudiation**.

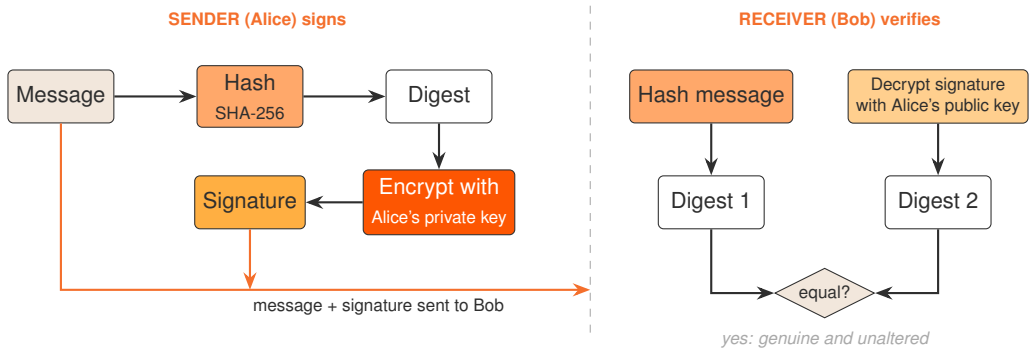


Figure: creating and verifying a digital signature.

5 Key distribution: KDC and Kerberos

Problem: with symmetric keys, n users need $n(n-1)/2$ secret keys and a safe way to deliver each one. **Solution**: a trusted **Key Distribution Centre** that shares one long-term key with each user (n keys) and issues short-lived **session keys** on demand.

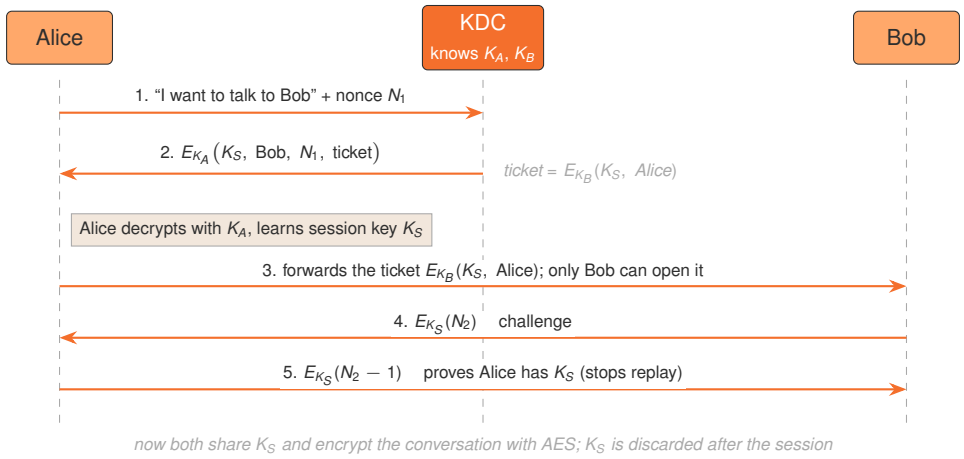


Figure: KDC session-key distribution (Needham–Schroeder style, the basis of Kerberos).

Kerberos splits the KDC into an **Authentication Server (AS)**, which logs the user in and gives a **Ticket-Granting Ticket (TGT)**, and a **Ticket-Granting Server (TGS)**, which exchanges the TGT for a service ticket. Tickets carry timestamps and expire (single sign-on in Windows Active Directory).

PAST PAPER **2023 Q4d(i)** **[3 marks]**

Define the following terms as applied in network security: Key distribution center.

Model answer

A **Key Distribution Centre** is a trusted third party in a symmetric-key system that shares a secret master key with every user and, on request, generates a temporary **session key** for two users and delivers it securely (encrypted under each user's master key, as a "ticket"). Each user then needs only one key with the KDC instead of one per partner (n keys instead of $n(n-1)/2$). Example: **Kerberos** (AS + TGS).

KDC = **symmetric** keys (session keys). CA = **public** keys (certificates). Mixing them up loses all 3 marks.

6 Certificate authorities and PKI

Problem: when Bob downloads "Alice's public key", how does he know it is not Mallory's? **Solution**: a **digital certificate** (X.509) that binds a public key to an identity, signed by a trusted **Certification Authority**. The whole system (CAs, registration authorities, certificates, CRLs, policies) is the **Public Key Infrastructure (PKI)**.

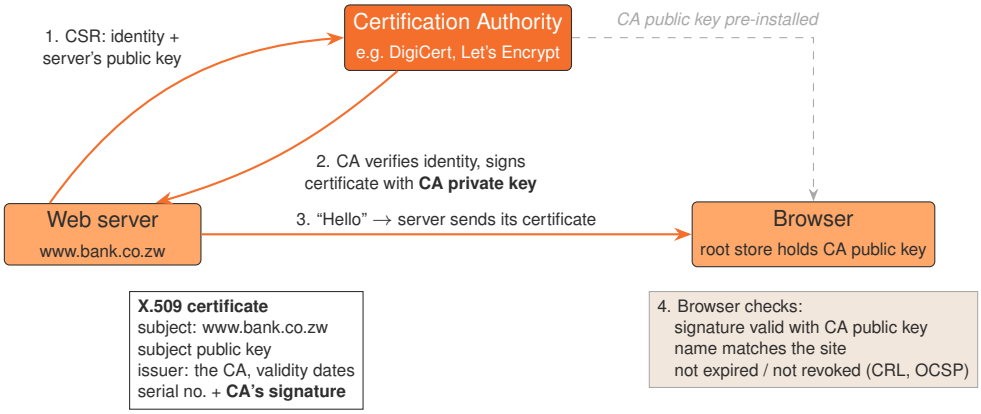


Figure: a CA issuing a certificate (1–2) and a client verifying it in a TLS handshake (3–4).

PAST PAPER **2023 Q4d(ii)** **[3 marks]**

Define the following terms as applied in network security: Certification authority.

Model answer

A **Certification Authority** is a trusted organisation in a Public Key Infrastructure that **verifies the identity** of a person, server or organisation and issues a **digital certificate** (X.509) binding that identity to its public key, **signed with the CA's private key**. Anyone can check the certificate with the CA's public key, which defeats man-in-the-middle key substitution. The CA also **revokes** compromised certificates (CRL / OCSP). Examples: DigiCert, GlobalSign, Let's Encrypt; used in HTTPS/TLS.

7 VPN, IPsec and SSL/TLS

A **Virtual Private Network** creates a secure, encrypted **tunnel** across a public network (the Internet) so that a remote user or branch office behaves as if it were directly on the private LAN.

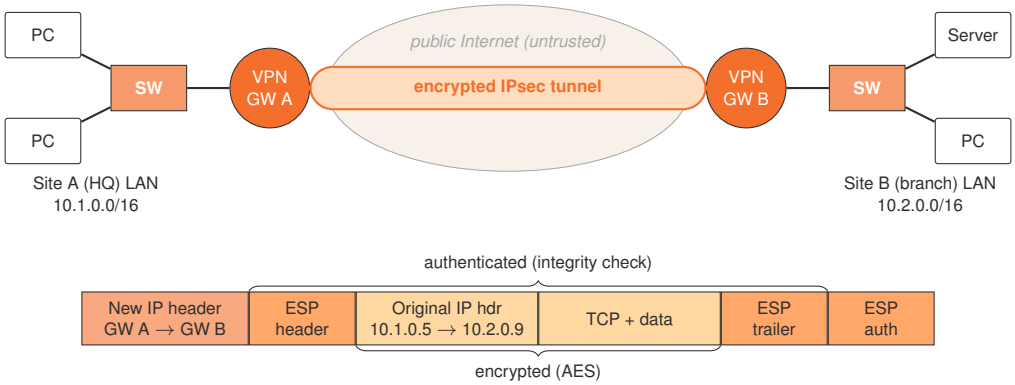


Figure: site-to-site VPN and an IPsec ESP tunnel-mode packet. The Internet sees only GW A → GW B.

PAST PAPER **ISA2024 Q2a** **[3 marks]**

VPN can be essential in network security, briefly explain how VPN works.

Model answer

1. **Authenticate and agree keys**: the VPN client (or branch gateway) and the VPN server authenticate each other (certificates, pre-shared key, username + MFA) and agree session keys (IKE in IPsec, the TLS handshake in SSL VPNs).
2. **Encrypt and encapsulate (tunnel)**: each original packet is encrypted (AES) and wrapped inside a new packet addressed to the VPN gateway, so it crosses the public Internet as unreadable ciphertext.
3. **Decapsulate and forward**: the gateway checks integrity, decrypts and forwards the original packet into the private LAN, as if the user were on site.

Gives confidentiality, integrity and authentication over a cheap public network. Types: remote-access and site-to-site; protocols IPsec, SSL/TLS, OpenVPN, WireGuard, L2TP/IPsec.

"How it works" for 3 marks = 3 steps: authenticate, encrypt + encapsulate, decrypt at the gateway. Draw the tunnel if time allows.

	IPsec	SSL/TLS
Layer	Network (layer 3)	Between transport and application (layers 4–7)
Protects	All IP traffic between two hosts or gateways	One application session (HTTPS, SMTPS, SSL VPN)
Parts	AH (authentication/integrity only), ESP (encryption + integrity), IKE (keys); transport or tunnel mode	Handshake (certificate, key exchange), record protocol (AES + MAC)
Typical use	Site-to-site VPNs, built into IPv6	Web browsing (port 443), remote-access VPN through a browser

8 Wireless security

Radio signals pass through walls, so anyone nearby can sniff Wi-Fi. Wireless needs both **authentication** (who may join) and **encryption** (protect frames in the air).

Standard	Year	Encryption	Notes
WEP	1999	RC4, 40/104-bit key, 24-bit IV	Broken: IV reuse lets the key be cracked in minutes. Never use.
WPA	2003	RC4 + TKIP	Stop-gap that ran on old WEP hardware; now deprecated.
WPA2	2004	**AES-CCMP**	Personal (PSK) or Enterprise (802.1X + RADIUS). 4-way handshake can be attacked offline if the passphrase is weak (KRACK flaw patched).
WPA3	2018	AES (GCMP-256 in Enterprise)	**SAE** replaces PSK (resists offline dictionary attacks), forward secrecy, protected management frames, OWE for open hotspots.

REMEMBER IT

Weak → Strong: **WEP** < **WPA** < **WPA2** < **WPA3**. RC4 = old and broken; AES = modern. Other good practice: change default admin passwords, disable WPS, use strong passphrases, guest VLAN, MAC filtering only as a weak extra.

WPA2/3 **Personal** = one shared passphrase for everyone. **Enterprise** = each user logs in via 802.1X + RADIUS, so one leaver does not force a new password for all.

9 Emerging technologies (week 12: modern trends)

Technology	What it is and why it matters
5G	Fifth-generation mobile network: up to ∼10 Gbps (eMBB), ∼1 ms latency (URLLC), up to a million devices per km^2 (mMTC). Uses network slicing (virtual networks per service) built on SDN/NFV. Enables IoT, smart cities, remote surgery.
Internet of Things	Billions of sensors and devices (smart meters, farm sensors, cameras) on the Internet. Needs IPv6 and low-power protocols (Zigbee, LoRaWAN, MQTT). Security risk: default passwords, no patches; Mirai botnet used IoT cameras for DDoS.
Cloud computing	On-demand, pay-as-you-go computing over the Internet. **IaaS** (virtual machines, e.g. AWS EC2), **PaaS** (platform to deploy apps, e.g. Google App Engine), **SaaS** (finished software, e.g. Gmail, Microsoft 365). Deployment: public, private, hybrid, community.
SDN	Software-Defined Networking separates the **control plane** (central SDN controller) from the **data plane** (switches) and programs them via OpenFlow. Central view, automation, fast changes.
NFV	Network Function Virtualisation runs firewalls, routers and load balancers as software (VMs) on standard servers instead of dedicated boxes. Cheaper, scalable.
Edge / fog computing	Processing data near where it is produced (base station, gateway) instead of a distant cloud: lower latency, less bandwidth. Needed for self-driving cars, AR, industrial IoT.
Others	Wi-Fi 6/7 (OFDMA), LEO satellite Internet (Starlink), AI-driven network management, Zero Trust security ("never trust, always verify"), blockchain.

Cloud **shared responsibility**: the provider secures the infrastructure; the customer still secures data, accounts and configuration. Most cloud breaches are misconfigurations.

10 Practice questions

PRACTICE Q1 EASY **[3 marks]**

State and explain the three goals of the CIA triad.

Answer

Confidentiality: only authorised users can read data (encryption). **Integrity**: data is not altered without detection (hashing, signatures). **Availability**: systems and data are accessible when needed (redundancy, DoS protection).

PRACTICE Q2 EASY **[4 marks]**

Distinguish between a passive and an active attack, giving one example of each.

Answer

A **passive** attack only monitors or copies traffic without changing it, so it is hard to detect; it threatens confidentiality. Example: sniffing passwords with Wireshark, traffic analysis. An **active** attack modifies, injects or blocks traffic, so it can be detected; it threatens integrity and availability. Example: DoS flood, spoofing, MITM modification, replay.

PRACTICE Q3 EASY **[3 marks]**

Why is WEP no longer considered secure, and what should replace it?

Answer

WEP uses the RC4 cipher with a short 24-bit IV that repeats on a busy network, so captured frames let an attacker recover the key in minutes; its integrity check (CRC-32) can also be forged. Replace it with **WPA2-AES (CCMP)** or, better, **WPA3** with SAE.

PRACTICE Q4 MEDIUM [6 marks]

Compare symmetric and asymmetric encryption under: keys, speed, key distribution and services provided. Give an example algorithm of each.

Answer

	Symmetric	Asymmetric
Keys	One shared secret key	Public/private key pair
Speed	Fast, for bulk data	Slow, for keys/signatures
Distribution	Hard: secret channel or KDC; $n(n-1)/2$ keys	Easy: public key published; $2n$ keys
Services	Confidentiality only	Confidentiality, authentication, non-repudiation
Example	AES, 3DES	RSA, ECC

PRACTICE Q5 MEDIUM [4 marks]

Differentiate between an IDS and an IPS.

Answer

An **IDS** monitors a copy of traffic (out of band), **detects** suspicious activity and **alerts** an administrator; it does not stop the attack. An **IPS** sits **inline** in the traffic path and **blocks** malicious packets automatically (drop, reset, block source). Both use signature- or anomaly-based detection; an IPS false positive can block legitimate traffic, an IDS false positive only causes an alert.

PRACTICE Q6 MEDIUM [6 marks]

Explain how a digital signature provides integrity, authentication and non-repudiation.

Answer

The sender hashes the message and encrypts the digest with their **private key**; the receiver decrypts it with the sender's **public key** and compares it with a fresh hash of the message. **Integrity**: if one bit of the message changed, the two digests would differ. **Authentication**: only the holder of the private key could produce a signature that the matching public key opens. **Non-repudiation**: since only the sender has the private key, they cannot later deny signing (the public key is bound to them by a CA certificate).

PRACTICE Q7 MEDIUM [6 marks]

Describe the three cloud service models, giving an example of each and stating who manages what.

Answer

IaaS: the provider supplies virtual servers, storage and networks; the customer manages the OS, middleware and apps (AWS EC2, Azure VMs). **PaaS**: the provider also manages the OS and runtime; the customer only deploys code and data (Google App Engine, Heroku). **SaaS**: the provider runs the complete application; the customer just uses it through a browser (Gmail, Microsoft 365, Zoom).

PRACTICE Q8 HARD **[10 marks]**

An organisation has 100 employees who must all be able to exchange encrypted messages in pairs. (a) How many secret keys are needed with plain symmetric encryption? (b) How many with a KDC? (c) How many keys with public-key encryption? (d) With the aid of a diagram, explain how a KDC gives two users a session key.

Answer

Working

$$\text{(a)}\ \frac{n(n-1)}{2} = \frac{100 \times 99}{2} = 4950 \text{ keys} \quad \leftarrow \textit{one per pair}$$

$$\text{(b) KDC} = n = 100 \text{ long-term keys} \quad \leftarrow \textit{each user shares one with the KDC}$$

$$\text{(c) public key} = 2n = 200 \text{ keys (100 pairs)} \quad \leftarrow \textit{public keys are not secret}$$

(d) Draw the KDC sequence diagram from Section 5. Alice asks the KDC for a key with Bob (with nonce N_1); the KDC returns $E_{K_A}(K_S, \text{Bob}, N_1, \text{ticket})$ where ticket = $E_{K_B}(K_S, \text{Alice})$; Alice forwards the ticket to Bob, who decrypts it with K_B; Bob challenges with $E_{K_S}(N_2)$ and Alice answers $E_{K_S}(N_2 - 1)$, proving both hold K_S and preventing replay. The session key is temporary and discarded after use. Kerberos implements this with an AS and TGS and time-limited tickets.

PRACTICE Q9 HARD **[10 marks]**

With the aid of a diagram, explain a man-in-the-middle attack on an online banking login and show how HTTPS with certificates defeats it.

Answer

Draw Alice, Mallory and the bank as in Section 1. **Attack**: Mallory positions himself between the victim and the bank (ARP spoofing on the LAN, DNS spoofing or a rogue Wi-Fi hotspot). The victim's packets go to Mallory, who reads the username and password and relays them to the bank, so neither side notices; he can also change transfer details (active attack on integrity) or capture session cookies. **Defence with HTTPS/TLS**: (1) the bank sends its X.509 certificate signed by a CA; (2) the browser verifies the CA signature with the CA public key in its root store and checks the domain name and expiry; (3) Mallory cannot produce a valid certificate for the bank's name because he lacks the CA's private key, so the browser shows a warning; (4) the client and the genuine server agree a session key, and all data is AES-encrypted and integrity-protected, so Mallory sees only ciphertext. Extra: HSTS forces HTTPS; MFA limits stolen-password damage; users must not click through certificate warnings.

PRACTICE Q10 HARD **[12 marks]**

A company has a head office in Harare and a branch in Bulawayo. It runs a public web and mail server and an internal database. With the aid of a labelled diagram, design and justify a secure network architecture.

Answer

Diagram: Internet → edge router → stateful/next-generation firewall with three legs: (i) DMZ with web and mail servers, (ii) internal LAN with switches, VLANs and the database server, (iii) outside. An IPS inline behind the firewall. A site-to-site IPsec VPN from the head-office gateway to the branch gateway across the Internet (as in Sections 3 and 7). **Justification**:

1. **Firewall rules**: allow inbound only HTTPS (443) and SMTP (25) to the DMZ; deny all inbound to the LAN except replies (stateful).
2. **DMZ**: a compromised web server does not give direct access to the database.
3. **IPS/IDS**: detects and blocks known attack signatures and anomalies; logs to the administrator.
4. **VPN**: IPsec ESP tunnel mode with AES encrypts branch traffic over the cheap public Internet; gateways authenticate with certificates.
5. **Segmentation**: VLANs separate finance, staff and guest Wi-Fi; ACLs between them.

6. **Wireless**: WPA3-Enterprise with 802.1X/RADIUS.
7. **Hosts and people**: antivirus, patching, backups, MFA, security awareness training.

PRACTICE Q11 HARD **[10 marks]**

Discuss 5G and the Internet of Things as emerging technologies, explaining how they relate and the security challenges they create.

Answer

5G: enhanced mobile broadband (up to $\sim$10 Gbps), ultra-reliable low latency ($\sim$1 ms) and massive machine-type communication (about 10^6 devices/km^2); uses network slicing on SDN/NFV and edge computing. **IoT**: everyday objects with sensors and network connections (smart meters, irrigation sensors, health monitors) sending data to cloud platforms; relies on IPv6 and low-power protocols (Zigbee, LoRaWAN, MQTT). **Relation**: 5G's mMTC and low latency are what allow very large IoT deployments and real-time uses (self-driving cars, remote surgery); edge computing processes IoT data near the source. **Security challenges**: huge attack surface; cheap devices with default passwords and no updates (Mirai botnet DDoS); weak encryption on low-power devices; privacy of collected personal data; software-based 5G core (SDN/NFV) can be attacked like any software; slicing isolation must be enforced. **Mitigations**: unique credentials, secure boot and firmware updates, encryption (TLS/DTLS), network segmentation of IoT devices, IDS monitoring, Zero Trust.

ONE-PAGE CHEAT SHEET

Goals: CIA = Confidentiality (encryption), Integrity (hash, signature), Availability (anti-DoS) + Authentication, Non-repudiation.
Attacks: passive (sniffing, traffic analysis) vs active (spoofing, DoS/DDoS, MITM, replay). Phishing = social engineering.
Malware

- Virus: host file + user
- Worm: self-replicates over network
- Trojan: disguised, backdoor, no self-copy
- Ransomware: encrypts files, demands ransom
- Spam: bulk e-mail, carries phishing

Firewall: packet filter, stateful, proxy, NGFW. **DMZ** = public servers zone. **IDS** detects + alerts; **IPS** inline, blocks. Signature vs anomaly.
Wi-Fi: WEP (RC4, broken) $<$ WPA (TKIP) $<$ WPA2 (AES-CCMP) $<$ WPA3 (SAE).

Symmetric: one key, fast, AES/DES, $n(n-1)/2$ keys.
Asymmetric: public + private, slow, RSA/ECC, $2n$ keys.
DES: 56-bit key, 64-bit block, 16 Feistel rounds, broken.
AES: 128/192/256 key, 128-bit block, 10/12/14 rounds, SPN, secure.
Signature: hash, encrypt with sender **private** key; verify with sender **public** key.
KDC: trusted 3rd party, shares K_A, K_B; issues session key K_S + ticket $E_{K_B}(K_S)$. Kerberos = AS + TGS, tickets expire.
CA: verifies identity, signs X.509 certificate (identity + public key) with CA private key; revokes (CRL/OCSP). PKI.
VPN: authenticate, encrypt + encapsulate in new IP packet, gateway decrypts. IPsec (L3: AH, ESP, IKE; tunnel/transport), SSL/TLS (port 443). Remote-access or site-to-site.
Emerging: 5G (10 Gbps, 1 ms, slicing), IoT, cloud IaaS/PaaS/SaaS, SDN (control vs data plane), NFV, edge.